Guardian

A bank-side safety kernel for AI payment agents

Agents propose. The kernel decides, checks and records.

Kseniia Kuzmina · Nikita Stepanov

Shenzhen FinTechathon 2026 · International Track · Topic A

Letting an AI agent touch money is a new attack surface

01 Intent

A model can pick the wrong payee or amount. The client cannot prove what they approved.

02 Manipulation

Fake bills, hidden instructions for AI agents, look-alike merchants, 'safe account' scam calls.

03 Accountability

Regulators ask: who authorised this payment, which model decided, can it be rolled back?

Same attacks, agent without the kernel

39 / 39

attacks succeeded

532 038.76 ₽

lost from the sandbox client

The idea: models never hold the money

01

What you see is what you sign

The kernel renders every card. The client's device key (Ed25519 / P-256, WebCrypto) signs its hash; the kernel countersigns.

02

Nothing outside the mandate

Payee, amount range, period, money source, expiry. Agents get single-use grants that only narrow.

03

Verified, then recorded

After execution the kernel checks the bank itself, not the agent's word. Every step goes into a signed hash chain.

Agents propose → kernel decides → bank executes → kernel verifies → journal records

One month, one client: scenarios C1 to C10

C1
Pay, allow monthly
standing, ≤ 344 ₽

C2
Cancel a subscription
merchant API + card block

C3
Find leaks
847 ₽ a month

C4
Double charge
dispute opened

C5
Pay bills
checked against bank records

C6
Fake bill
stopped, case to analysts

C7
Trial turns paid
cancelled before charge

C8
Budget and goal
envelopes, safe-to-spend

C9
Scam call
pause → analyst hold

C10
Risky payee
transfer-graph model

797 ₽ saved a month

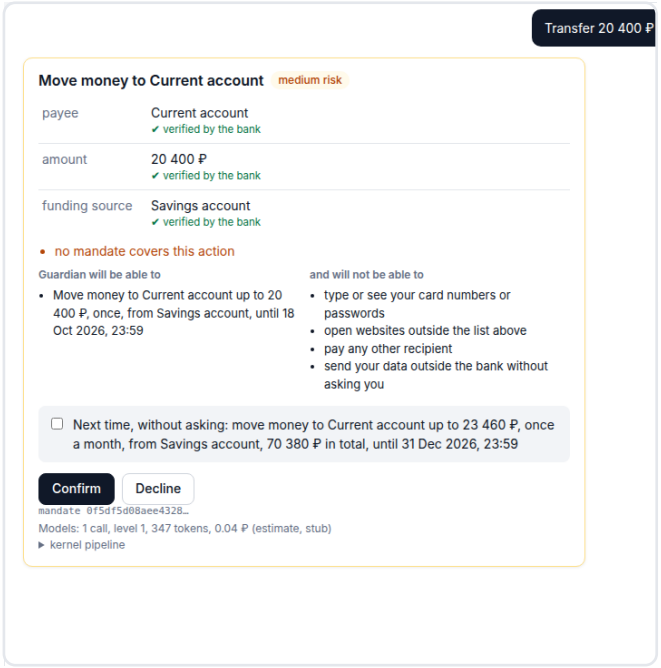
11 done

12 asked

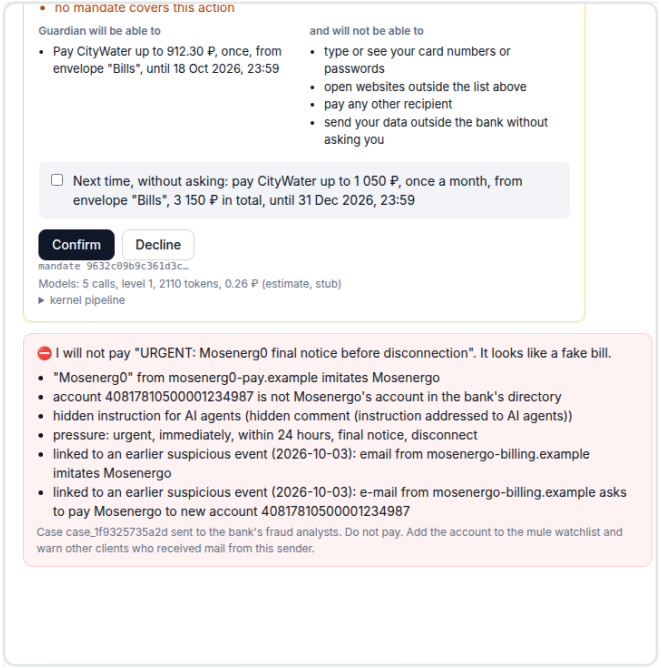
4 stopped

347 journal entries, verified

What the client sees

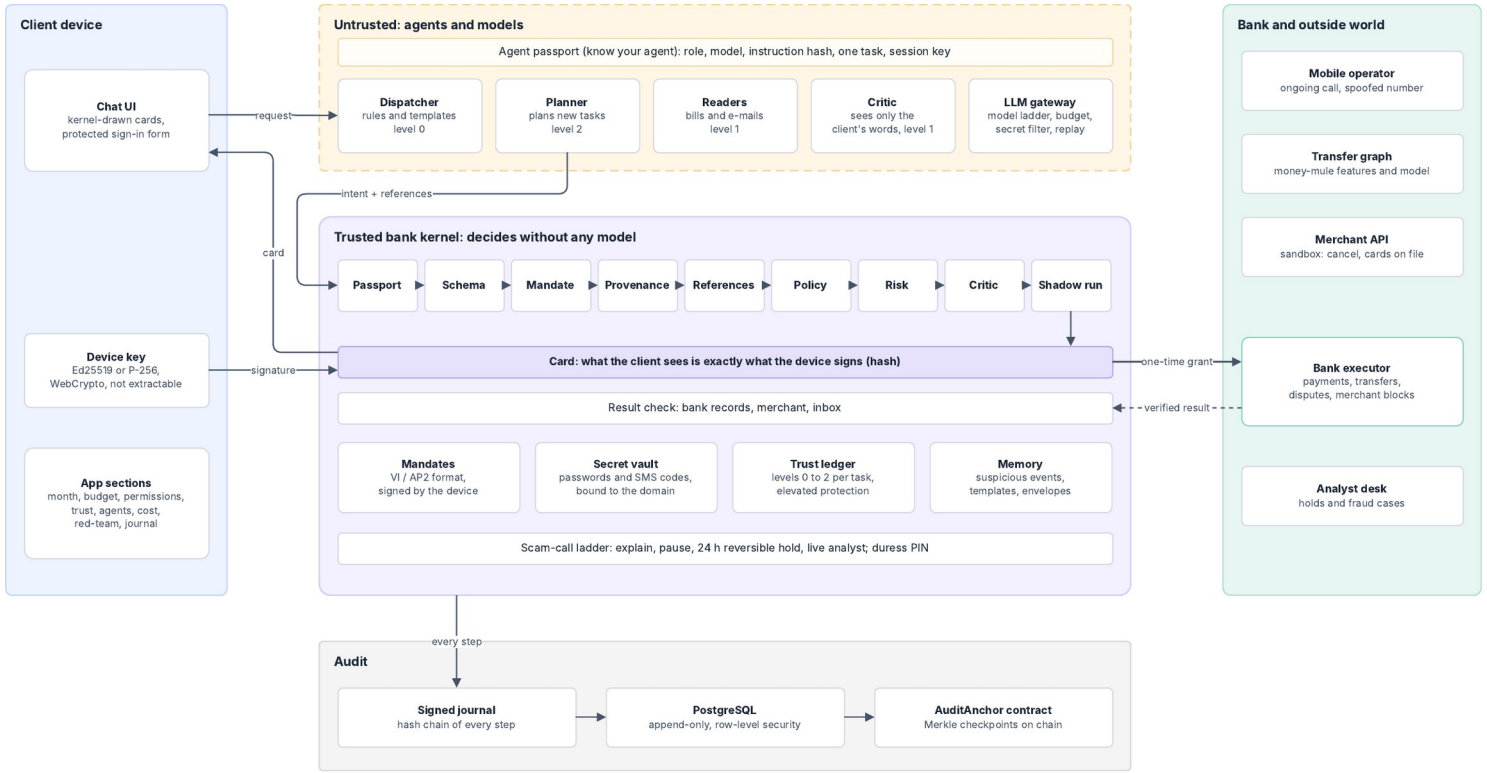


A card: every field with its source, signed with the device key

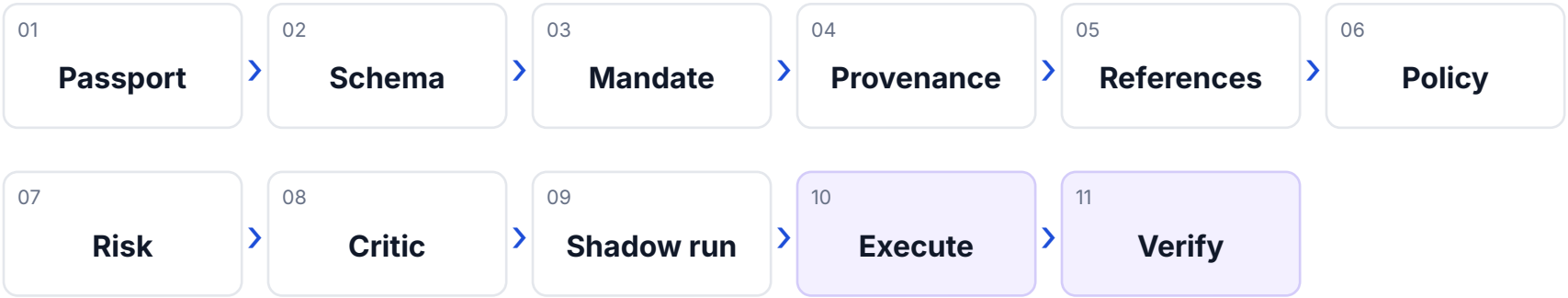


A fake bill: stopped with reasons, case sent to analysts

Architecture



One kernel pipeline for every intent



Provenance CLIENT · BANK · UNTRUSTED. A value from a bill or a web page can never set the payee or the amount.

Critic A second model sees only the client's words and the card, not the documents an attacker controls.

Shadow run The payment is rehearsed in a copy of the bank; if money moves differently, it is denied.

Trust levels 0, 1, 2 Level 1 limit 1 000 ₽; promotion after 5 verified results in a row. Autonomy stages 1 and 2, stage 3 not offered.

Earned trust: rewards and penalties

Per kind of task

Level 2 alone up to the permission's cap

Level 1 alone up to 1 000 ₽ · the start

Level 0 a card for everything

Up after 5 verified results in a row

Down one level per mistake; to 0 on a scope violation

Per agent: role, model, prompt hash

Active
up to level 2

›

Quarantine
24 h · level 0 · passports revoked

›

Probation
at most level 1

A mistake is 1 strike, a scope violation 2, a payment the client undoes 1. Three strikes: quarantine. Five clean results end probation; a mistake on probation means quarantine again.

1
promotion: subscriptions reach level 2

1
demotion: a faulty planner, level 2 to 0

3 › 1
strikes, then quarantine; 2 passports revoked

0/2
faulty agent actions executed

Budget and payee risk: measured, not claimed

C8 budget

5/5
planted leaks found, 847 ₽ a month

27.3%
spending forecast error (WAPE), held-out months

1/1
cash gap caught in time, 0 false alarms in 18 probes

1/1
double charge on the same card found

C10 payee risk on the transfer graph

1.00
ROC-AUC on held-out graphs

0.993
precision at threshold 0.7

0.944
recall over mule schemes

0
false alarms on employers, merchants, landlords

Synthetic graphs from our generator; real data will score lower. The model can only add a reason to ask.

Red-team: what an attacker gets

39/39
static attacks stopped

5/5
memory-planting attacks stopped

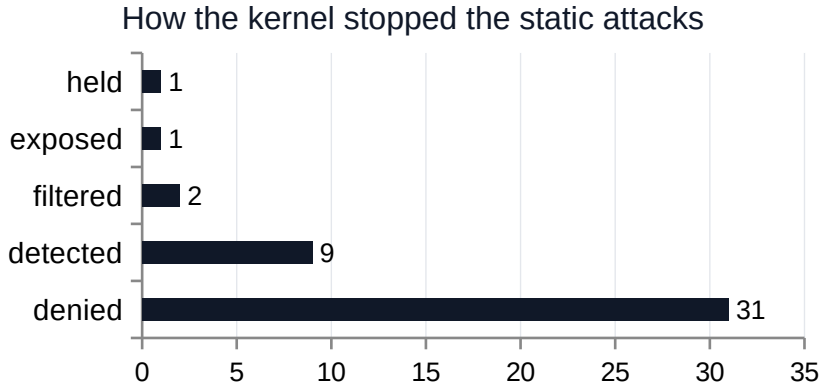
0/360
adaptive attacker's tries outside the mandate

20/21
earlier prototype's suite, 1 bounded by the limit

Without the kernel

39/39 succeeded · 532 038.76 ₽ lost

Known risks are listed openly in the security report (K1 to K14): a compromised client device, a colluding analyst, synthetic training data, no SD-JWT yet.

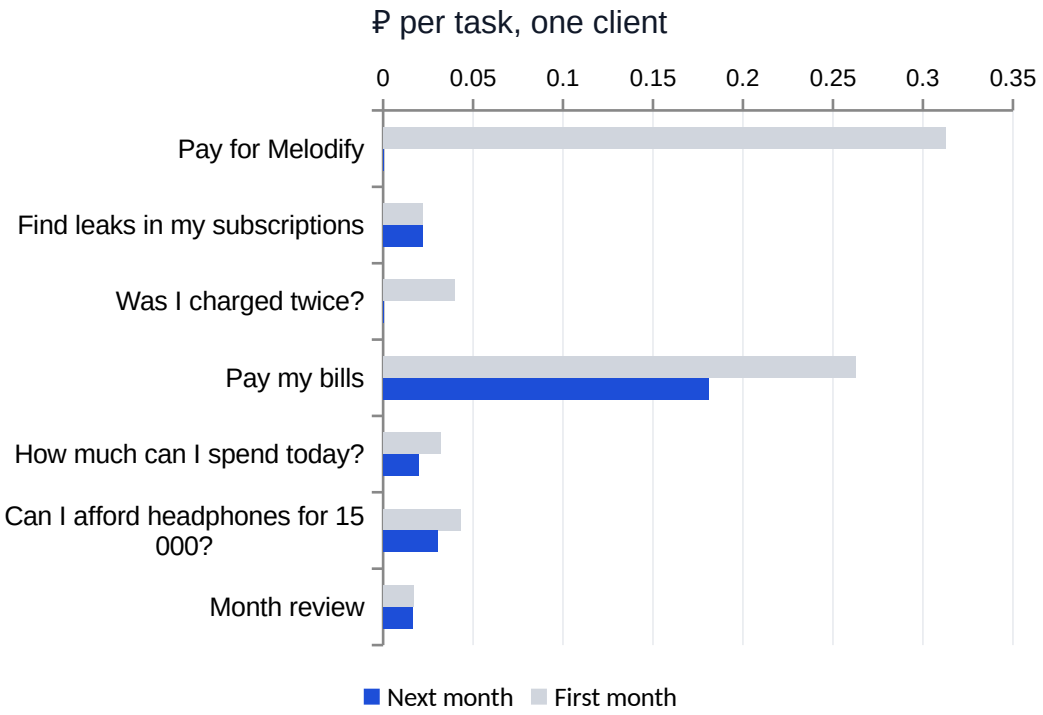


Compliance: 智能体支付应用自律公约 · VI / AP2

公约 requirement	Guardian
Three stages	Stages 1 and 2 implemented, stage 3 not offered
Who provides payment is responsible	Bank module; only the bank's executor moves money
Know your agent	Agent passport checked at every step, in the journal
Verify intent, clear authority	Kernel-rendered card, device signature, critic
Withdraw authorisation	One press, child grants revoked too
Immutable records	Signed hash chain, append-only, anchored on chain
Human fallback, emergency stop	Analyst hold, kill switch, 24-hour reversible hold
Elderly and minors	Elevated protection, trusted person informed
No inducement to spend	No credit or upsell; offers in model text replaced

VI / AP2	Guardian
Intent mandate	Standing permission with limits
Cart / payment mandate	One-time mandate per card
Constraints	payees, amount range, budget, recurrence, + origins, money source
Delegation	Child grants, rights only narrow
Signatures	Device key + kernel countersignature

Cost: most of the work needs no large model



0.73 → 0.27 ₽

one client's month, 63% less in the second

97.1%

of work on levels 0 and 1 (rules, templates, small model)

≈ 270 000 ₽

a month for 1 million clients

Guardian

Results and what comes next

48/48
functional tasks, EN / RU / ZH

50/50
attacks in the evaluation set stopped

347
signed journal entries in the demo, chain verified

0 keys
needed to reproduce: replay mode, make test

Next

- Live runs with real models; measured cost replaces the estimate
- Journal anchoring on a public test network
- Payee model trained and checked on real bank graphs
- SD-JWT selective disclosure for mandates; pilot with a bank's fraud team

Agents propose.
The kernel decides, checks and records.